

Network and Cyber Security

Bachelor in Computer Engineering

Er. Anuj Sherchan
Assistant Professor

Unit 4: Authentication System and Key Establishment

- Outline:
- 4.1 Hash, Secure Hash Algorithm (SHA)
- 4.2 Authentication in Symmetric Key Cryptography
 - 4.2.1 Message Authentication Code (MAC),
 - 4.2.2 Message Digest (MD),
 - 4.2.3 HMAC - Prefix, Suffix and Nested
- 4.3 Authentication in Asymmetric Key Cryptography
 - 4.3.1 Digital Signature
 - 4.3.2 RSA Digital Signature
 - 4.3.3 Digital Signature Standard
- 4.4 Key Establishment
 - 4.4.1 n2 Key Distribution Problem
 - 4.4.2 Key Distribution Centre
 - 4.4.3 Man-In-the-Middle (MIM) Attack
 - 4.4.4 Digital Certificate

Hash, Secure Hash Algorithm (SHA)

- **Hashing**
- **Hashing** is a one-way mathematical function that turns data into a string of nondescript text that cannot be reversed or decoded.
- In the context of cybersecurity, **hashing** is a way to keep sensitive information and data — including passwords, messages, and documents — secure.
- Once this content is converted via a hashing algorithm, the resulting value (or hash code) is unreadable to humans.
- It is extremely difficult to decrypt, even with the help of advanced technology.

Hash, Secure Hash Algorithm (SHA)

- Hashing has become an important cybersecurity tool for organizations, especially given the rise in remote work and use of personal devices.
- Both of these trends require organizations to leverage **single sign-on (SSO) technology** to enable a remote workforce and reduce friction within the user experience.
- Though this is a necessary part of modern business, attackers have come to recognize the inherent vulnerability of stored passwords and user credentials, which means that companies must take additional steps to keep that information secure.

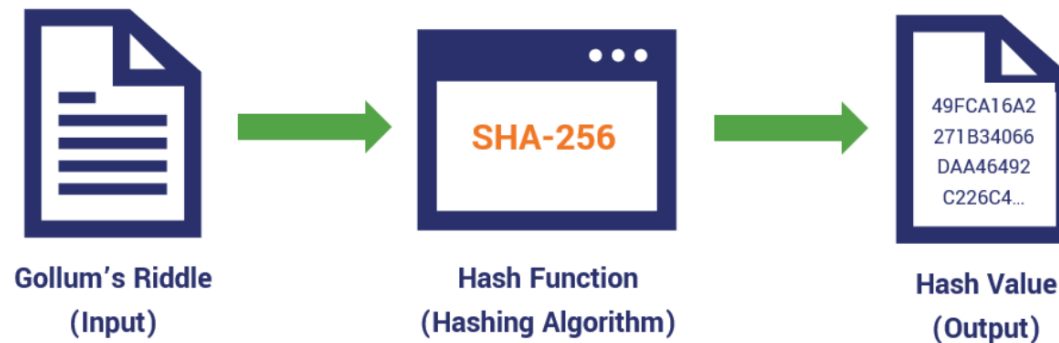
Hash, Secure Hash Algorithm (SHA)

- **Components of hashing**
 - Hashing has three main components:
 - **The input key**
 - **The hash function**
 - **The hash table**
-
- **The input key**
 - The input data or message that is processed by the hash function and converted into the hash code.

Hash, Secure Hash Algorithm (SHA)

- **The hash function**
- A mathematical function that converts the input data, or key, into a unique hash value.
- **The hash table**
- A data structure that stores data and maps keys to values.

How Hashing Works



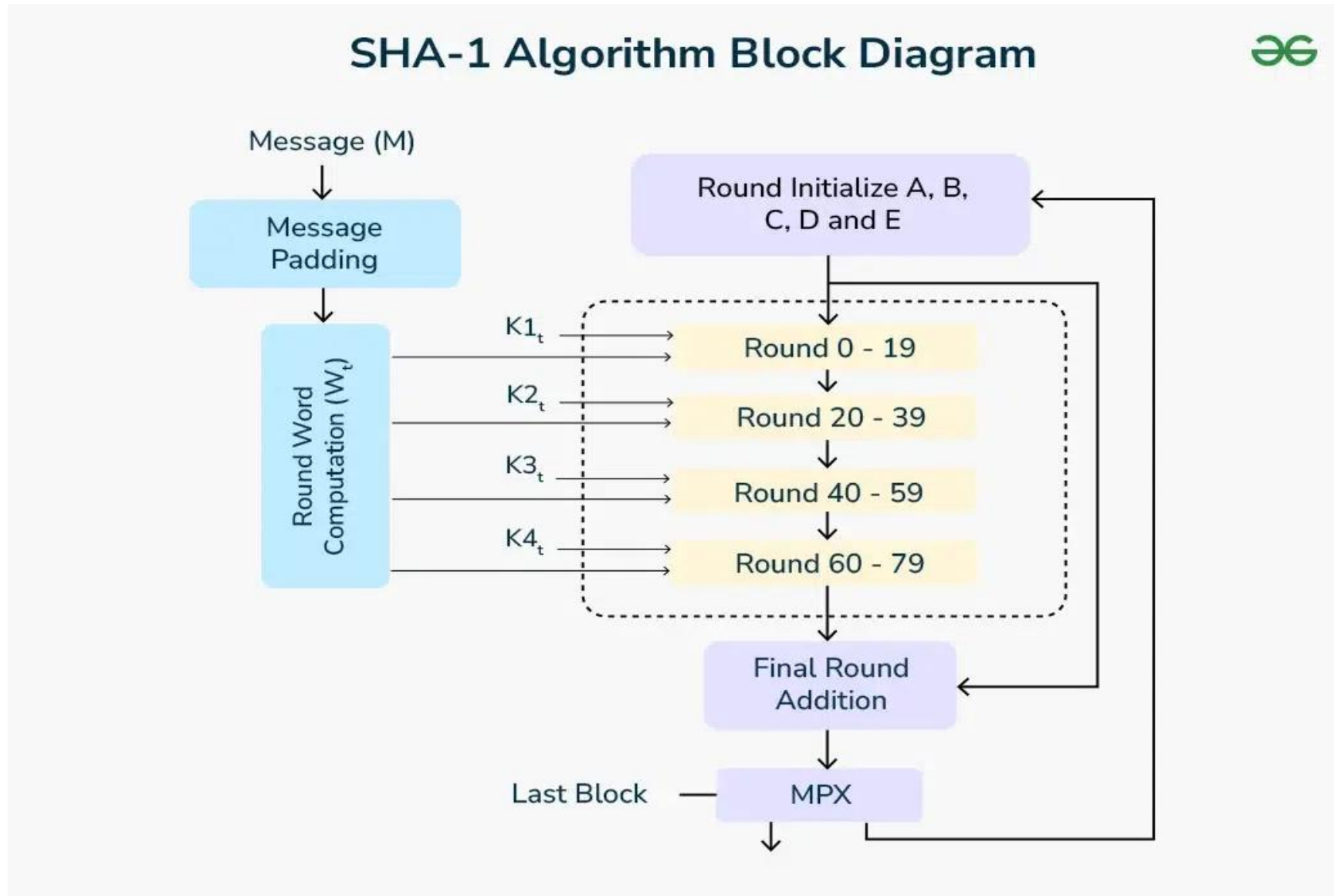
Hash, Secure Hash Algorithm (SHA)

- **Secure Hash Algorithm(SHA)**
- The most widely used hash function has been the Secure Hash Algorithm (SHA).
- SHA was developed by the National Institute of Standards and Technology (NIST) and published as a federal information processing standard (FIPS 180) in 1993.
- SHA is based on the hash function MD4, and its design closely models MD4.
- Three new versions of SHA, with hash value lengths of 256, 384, and 512 bits, known as SHA-256, SHA-384, and SHA-512, respectively.
- Collectively, these hash algorithms are known as SHA-2.

Hash, Secure Hash Algorithm (SHA)

- **SHA-1 Hash**
- SHA-1 or Secure Hash Algorithm 1 is a cryptographic algorithm that takes an input and produces a 160-bit (20-byte) hash value.
- This hash value is known as a message digest.
- This message digest is usually then rendered as a hexadecimal number which is 40 digits long.
- It is a U.S. Federal Information Processing Standard and was designed by the United States National Security Agency.
- SHA-1 is been considered insecure since 2005.
- Major tech giants browsers like Microsoft, Google, Apple, and Mozilla have stopped accepting SHA-1 SSL certificates by 2017.

Hash, Secure Hash Algorithm (SHA)



Hash, Secure Hash Algorithm (SHA)

- **How SHA-1 Works**
- **Components and Process Flow:**
- **Message (M):**
 - The original input message that needs to be hashed.
- **Message Padding:**
 - The initial step where the message is padded to ensure its length is congruent to 448 modulo 512.
 - This step prepares the message for processing in 512-bit blocks.
- **Round Word Computation (W_t W_{t+1}):**
 - After padding, the message is divided into blocks of 512 bits, and each block is further divided into 16 words of 32 bits.
 - These words are then expanded into 80 32-bit words, which are used in the subsequent rounds.

Hash, Secure Hash Algorithm (SHA)

- **Round Initialize (A, B, C, D, and E):**
 - Initialization of five working variables (A, B, C, D, and E) with specific constant values. These variables are used to compute the hash value iteratively.
- **Round Constants (K₁, K₂, K₃, K₄):**
 - SHA-1 uses four constant values (K₁, K₂, K₃, K₄), each applied in a specific range of rounds:
 - K₁ for rounds 0-19
 - K₂ for rounds 20-39
 - K₃ for rounds 40-59
 - K₄ for rounds 60-79

Hash, Secure Hash Algorithm (SHA)

- **Rounds (0-79):**
 - The main computation loop of SHA-1, divided into four stages (each corresponding to one of the constants K_1 to K_4).
 - In each round, a combination of logical functions and operations is performed on the working variables (A, B, C, D, and E) using the words generated in the previous step.
- **Final Round Addition:**
 - After all 80 rounds, the resulting values of A, B, C, D, and E are added to the original hash values to produce the final hash.
- **MPX (Multiplexing):**
 - Combines the results from the final round addition to form the final message digest.

Hash, Secure Hash Algorithm (SHA)

- **Applications:**
- Cryptography
- Data Integrity
- Digital Signatures
- Digital Forensics
- Password Storage
- Software Updates

Authentication in Symmetric Key Cryptography

- **Message Authentication**
- Message authentication is a procedure to verify that received messages come from the alleged source and have not been altered.
- Message authentication may also verify sequencing and timeliness.
- It is intended against the attacks like content modification, sequence modification, timing modification and repudiation.
- For repudiation, concept of digital signatures is used to counter it.
- There are three classes by which different types of functions that may be used to produce an authenticator.

Authentication in Symmetric Key Cryptography

- **Message encryption**
 - the ciphertext serves as authenticator.
- **Message authentication code (MAC)**
 - a public function of the message and a secret key producing a fixed-length value to serve as authenticator.
 - This does not provide a digital signature because A and B share the same key.
- **Hash function**
 - a public function mapping an arbitrary length message into a fixed-length hash value to serve as authenticator.
 - This does not provide a digital signature because there is no key.

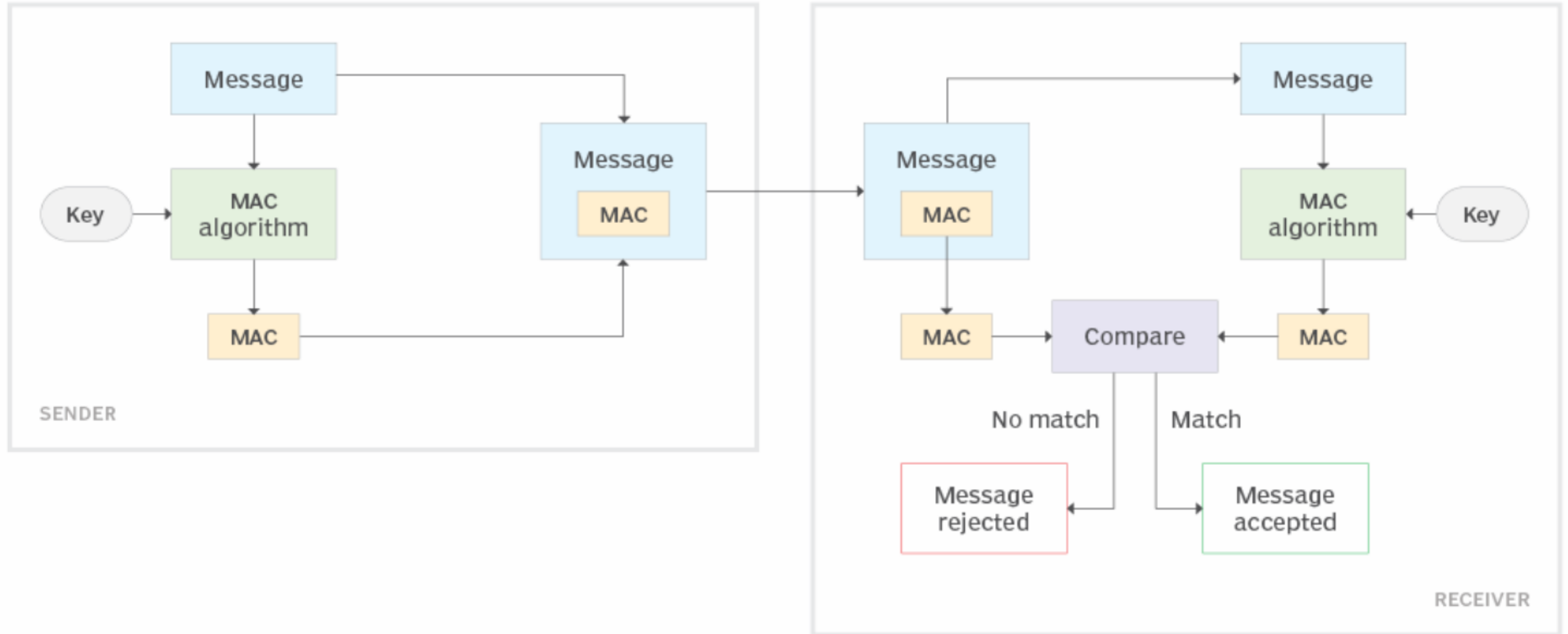
Authentication in Symmetric Key Cryptography

- **MESSAGE AUTHENTICATION CODE**
- An alternative authentication technique involves the use of a secret key to generate a small fixed-size block of data, known as cryptographic checksum or MAC, which is appended to the message.
- This technique assumes that both the communicating parties say A and B share a common secret key K.
- When A has a message to send to B, it calculates MAC as a function C of key and message given as: $MAC = C_k(M)$
- The message and the MAC are transmitted to the intended recipient, who upon receiving performs the same calculation on the received message, using the same secret key to generate a new MAC.

Authentication in Symmetric Key Cryptography

- The received MAC is compared to the calculated MAC and only if they match, then:
 - 1. The receiver is assured that the message has not been altered: Any alternations been done the MAC's do not match.
 - 2. The receiver is assured that the message is from the alleged sender: No one except the sender has the secret key and could prepare a message with a proper MAC.
 - 3. If the message includes a sequence number, then receiver is assured of proper sequence as an attacker cannot successfully alter the sequence number.

Generating and verifying message authentication codes



Authentication in Symmetric Key Cryptography

- **Limitations of MAC**
- **Establishment of Shared Secret.**
 - It can provide message authentication among pre-decided legitimate users who have shared key.
 - This requires establishment of shared secret prior to use of MAC.
- **Inability to Provide Non-Repudiation**
- Non-repudiation is the assurance that a message originator cannot deny any previously sent messages and commitments or actions.
- MAC technique does not provide a non-repudiation service.
- If the sender and receiver get involved in a dispute over message origination, MACs cannot provide a proof that a message was indeed sent by the sender.

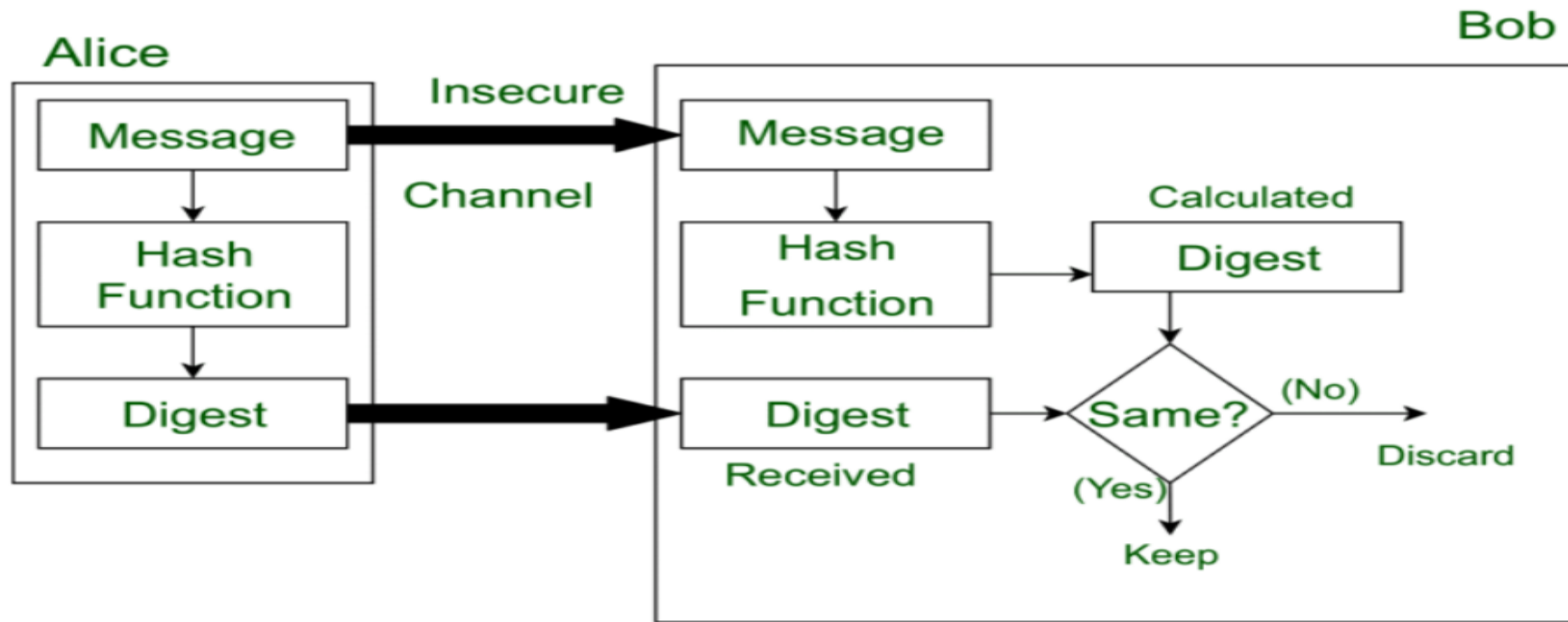
Authentication in Symmetric Key Cryptography

- **Message Digest**
- Message Digest is used to ensure the integrity of a message transmitted over an insecure channel (where the content of the message can be changed).
- It refers to a fixed-size numerical representation (hash value) of a message or data, created by a hash function.
- It's a core concept in ensuring data integrity.
- The message is passed through a Cryptographic hash function.
- This function creates a compressed image of the message called Digest.

Authentication in Symmetric Key Cryptography

Working of Message Digest

Lets assume, Alice sent a message and digest pair to Bob.



Working of Message Digest

This message and digest pair is equivalent to a physical document and fingerprint of a person on that document. Unlike the physical document and the fingerprint, the message and the digest can be sent separately.

Authentication in Symmetric Key Cryptography

- **Sender Side (Creating the Digital Signature)**
- **Compose the Message**
The sender writes or generates the message they want to send.
- **Generate the Message Digest**
The sender uses a cryptographic hash function (e.g., SHA-256) to create a message digest (fixed-length hash) from the original message.
- Example: $\text{Digest} = \text{Hash}(\text{Message})$
- **Encrypt the Digest with Private Key**
The sender encrypts the digest using their private key.
- This encrypted digest is now the digital signature.
- Example: $\text{Digital Signature} = \text{Encrypt}(\text{Digest}, \text{Sender's Private Key})$

Authentication in Symmetric Key Cryptography

- **Send the Message and Digital Signature**
The sender sends both the original message and the digital signature to the receiver.
- **Receiver Side (Verifying Integrity and Authenticity)**
- **Receive the Message and Digital Signature**
The receiver gets the original message and the attached digital signature.
- **Compute the Message Digest Locally**
The receiver uses the same hash function to compute a new digest from the received message.
- Example: $\text{Digest}' = \text{Hash}(\text{received message})$

Authentication in Symmetric Key Cryptography

- **Decrypt the Digital Signature**
- The receiver decrypts the digital signature using the sender's public key to recover the original digest.
- Example: $\text{Original Digest} = \text{Decrypt}(\text{Digital Signature}, \text{Sender's Public Key})$
- **Compare the Two Digests**
The receiver compares:
 - The locally generated digest (Digest')
 - The decrypted digest from the digital signature (Original Digest)

Authentication in Symmetric Key Cryptography

- There are two possibilities that happen:
- If they match:
 - The message has not been altered (integrity verified).
 - The sender is authenticated (only the true sender has the matching private key).
- If they do not match:
 - The message may have been tampered with, or the sender may be fraudulent.

Authentication in Symmetric Key Cryptography

- **Applications of Message Digest**
- **Digital Signatures:** Ensures the message is not been tampered .
- **Data Integrity Checks:** Verifies files/downloads have not be changed.
- **Password Hashing:** Securely stores passwords (usually with salt).

Authentication in Symmetric Key Cryptography

- **HMAC (Hash-Based Message Authentication Code)**
- is a cryptographic technique that ensures data integrity and authenticity using a hash function and a secret key.
- Checking data integrity is necessary for the parties involved in communication.
- HTTPS and other transfer protocols use HMAC.
- The cryptographic hash function may be MD-5, SHA-1, or SHA-256.
- Digital signatures are nearly similar to HMACs i.e. they both employ a hash function and a shared key.
- The difference lies in the keys i.e. HMAC uses a symmetric key(same copy) while Signatures uses an asymmetric (two different keys).

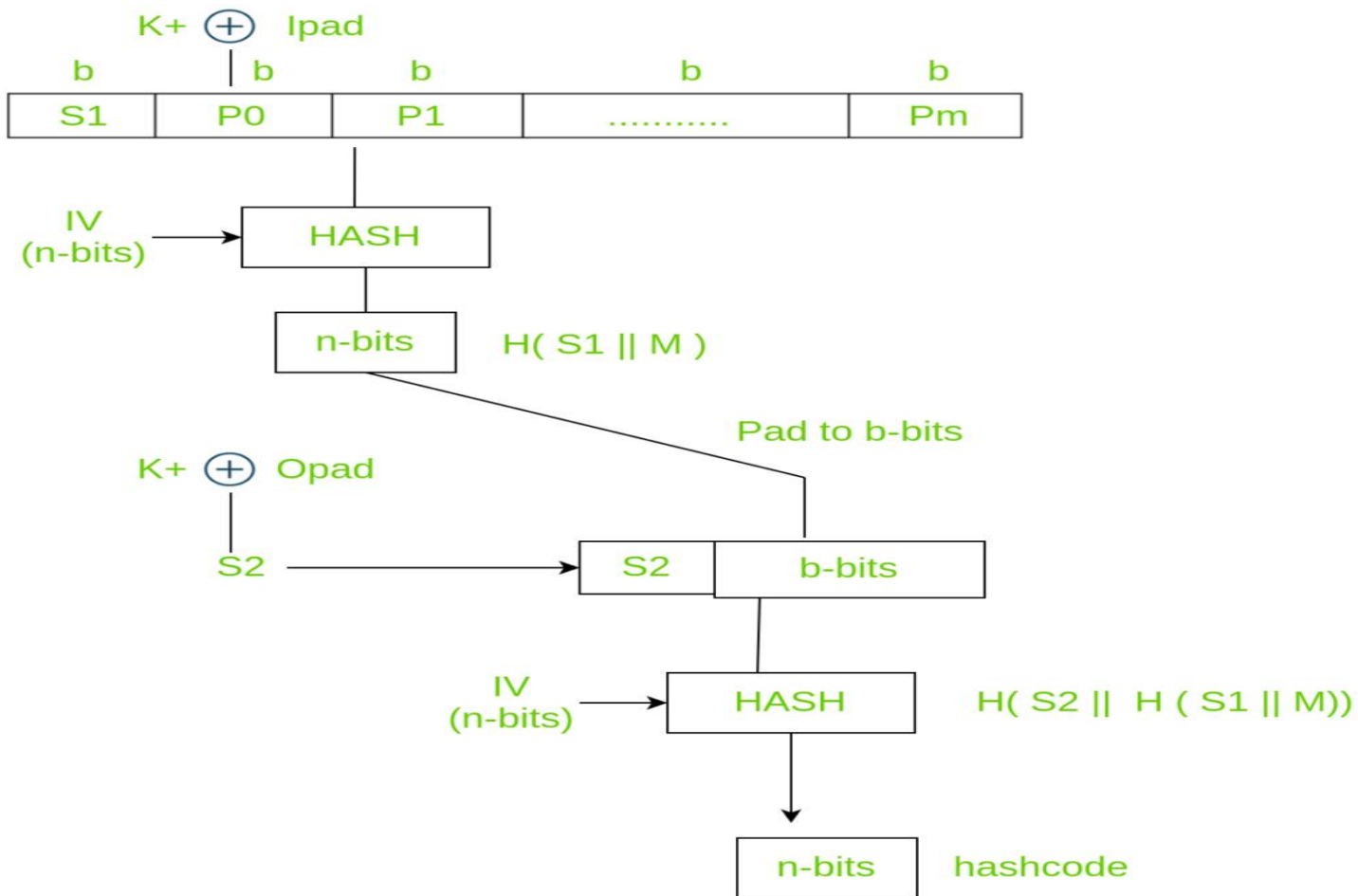
Authentication in Symmetric Key Cryptography

- **Working of Hash-based Message Authentication Code**
- HMACs provides client and server with a shared private key that is known only to them.
- The client makes a unique hash (HMAC) for every request.
- When the client requests the server, it hashes the requested data with a private key and sends it as a part of the request.
- Both the message and key are hashed in separate steps making it secure.
- When the server receives the request, it makes its own HMAC.
- Both the HMACS are compared and if both are equal, the client is considered legitimate.

Authentication in Symmetric Key Cryptography

- The formula for HMAC : **HMAC = hashFunc(secret key + message)**
- There are three types of authentication functions.
- They are message encryption, message authentication code, and hash functions.
- The major difference between MAC and hash (HMAC here) is the dependence of a key.
- In HMAC we have to apply the hash function along with a key on the plain text.
- The hash function will be applied to the plain text message.
- But before applying, we have to compute S bits and then append it to plain text and after that apply the hash function.
- For generating those S bits we make use of a key that is shared between the sender and receiver.

Authentication in Symmetric Key Cryptography



Authentication in Symmetric Key Cryptography

- Using key K ($0 < K < b$), K^+ is generated by padding 0's on left side of key K until length becomes b bits.
- The reason why it's not padded on right is change(increase) in the length of key. b bits because it is the block size of plain text.
- There are two predefined padding bits called ipad and opad.
- All this is done before applying hash function to the plain text message.
- ipad - 00110110
opad - 01011100

Authentication in Symmetric Key Cryptography

- **Now we have to calculate S bits:**
- K^+ is XORed with ipad and the result is S1 bits which is equivalent to b bits since both K^+ and ipad are b bits.
- We have to append S1 with plain text messages.
- Let P be the plain text message.
- S1, p0, p1 upto Pm each is b bits.
- m is the number of plain text blocks.
- P0 is plain text block and b is plain text block size.
- After appending S1 to Plain text we have to apply HASH algorithm (any variant).
- Simultaneously we have to apply initialization vector (IV) which is a buffer of size n-bits.
- The result produced is therefore n-bit hash code i.e. $H(S1 || M)$.

Authentication in Symmetric Key Cryptography

- Similarly, n -bits are padded to b -bits And K^+ is EXORed with opad producing output S_2 bits.
- S_2 is appended to the b -bits and once again hash function is applied with IV to the block.
- This further results into n -bit hashcode which is $H(S_2 \parallel H(S_1 \parallel M))$.

Authentication in Symmetric Key Cryptography

- **Applications of HMAC**

- Verification of e-mail address during activation or creation of an account.
- Authentication of form data that is sent to the client browser and then submitted back.
- HMACs can be used for Internet of things (IoT) due to less cost.
- Whenever there is a need to reset the password, a link that can be used once is sent without adding a server state.
- It can take a message of any length and convert it into a fixed-length message digest.
- That is even if you got a long message, the message digest will be small and thus permits maximizing bandwidth.

Authentication in Asymmetric Key Cryptography

- **Digital Signature**
- A digital signature is a mathematical technique used to validate the authenticity and integrity of a message, software, or digital document.
- These are some of the key features of it.
- **Key Generation Algorithms:**
- Digital signatures are electronic signatures, which assure that the message was sent by a particular sender.
- While performing digital transactions authenticity and integrity should be assured, otherwise, the data can be altered or someone can also act as if he were the sender and expect a reply.

Authentication in Asymmetric Key Cryptography

- **Signing Algorithms:**
- To create a digital signature, signing algorithms like email programs create a one-way hash of the electronic data which is to be signed.
- The signing algorithm then encrypts the hash value using the private key (signature key).
- This encrypted hash along with other information like the hashing algorithm is the digital signature.
- This digital signature is appended with the data and sent to the verifier.

Authentication in Asymmetric Key Cryptography

- **Signature Verification Algorithms:**
- The Verifier receives a Digital Signature along with the data.
- It then uses a Verification algorithm to process the digital signature and the public key (verification key) and generates some value.
- It also applies the same hash function on the received data and generates a hash value.
- If they both are equal, then the digital signature is valid else it is invalid.

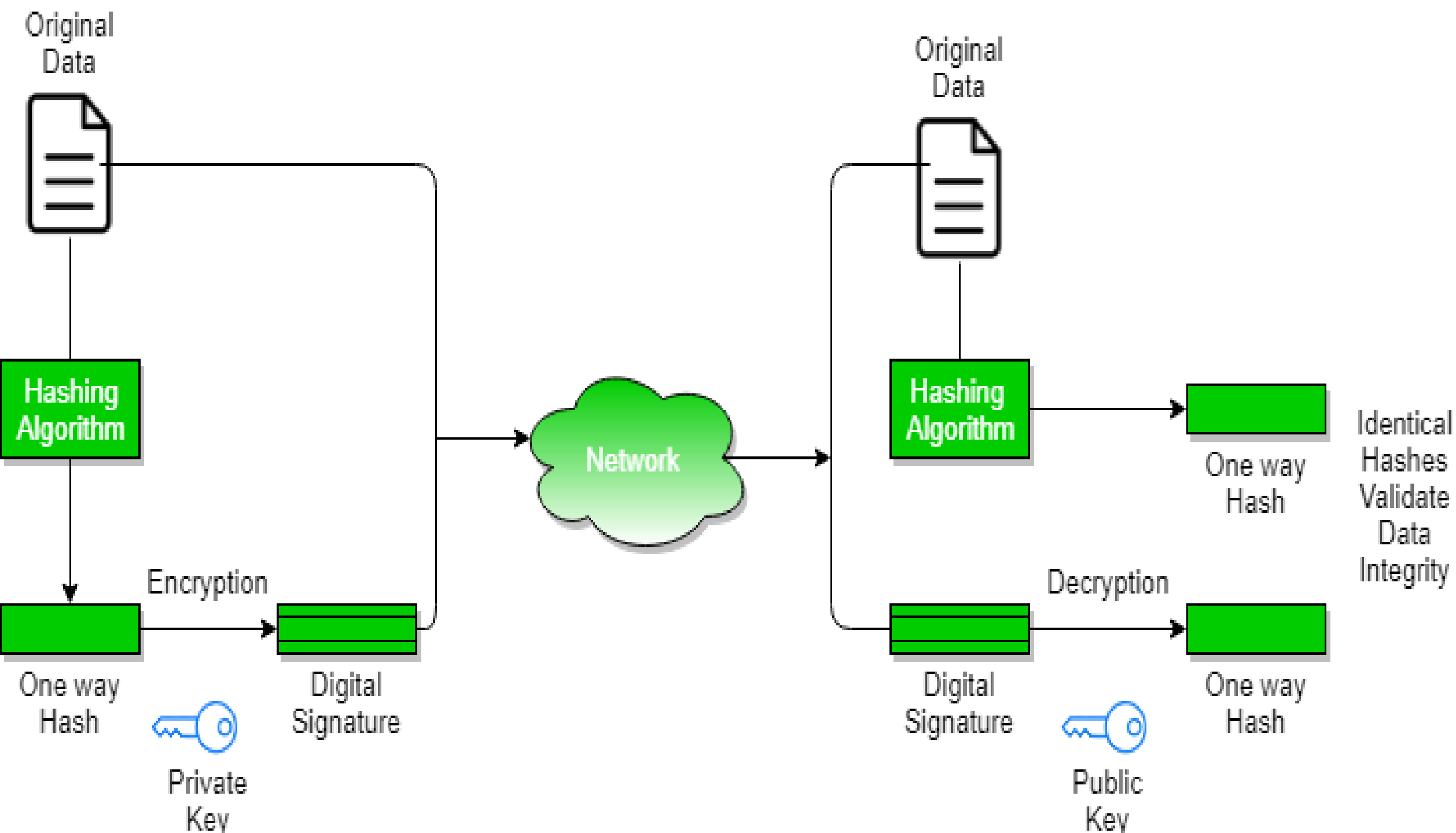
Authentication in Asymmetric Key Cryptography

- **How Digital Signature Works**

- The steps followed in creating a digital signature are:
- Message digest is computed by applying the hash function on the message and then message digest is encrypted using the private key of the sender to form the digital signature. (digital signature = encryption (private key of sender, message digest) and message digest = message digest algorithm (message)).
- A digital signature is then transmitted with the message. (message + digital signature is transmitted)
- The receiver decrypts the digital signature using the public key of the sender.
- (This assures authenticity, as only the sender has his private key so only the sender can encrypt using his private key which can thus be decrypted by the sender's public key).

Authentication in Asymmetric Key Cryptography

- The receiver now has the message digest.
- The receiver can compute the message digest from the message (actual message is sent with the digital signature).
- The message digest computed by receiver and the message digest (got by decryption on digital signature) need to be same for ensuring integrity.



Authentication in Asymmetric Key Cryptography

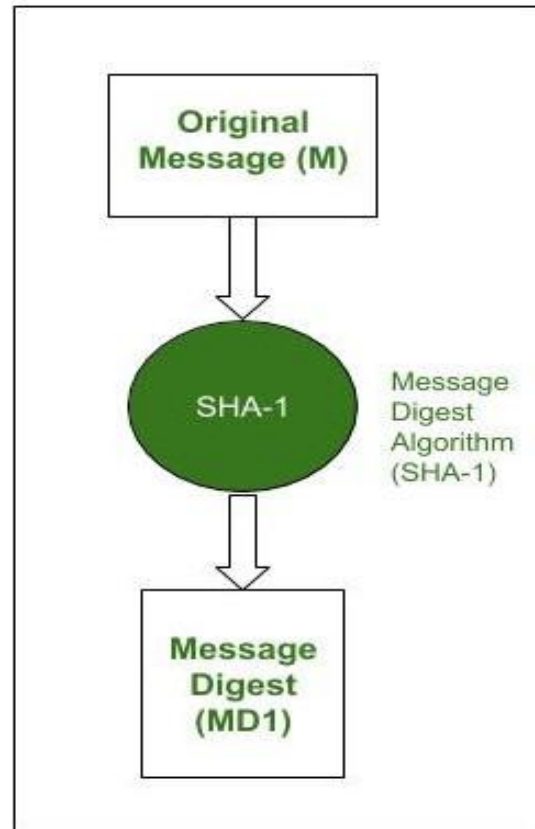
- **RSA Digital Signature**
- RSA and digital signatures are crucial elements in modern cybersecurity.
- RSA, a widely used encryption algorithm, ensures secure data transmission by encrypting and decrypting information.
- Digital signatures, on the other hand, authenticate the identity of the sender and guarantee the integrity of the message.
- Together, RSA and digital signatures provide a robust framework for secure communication, protecting sensitive data from unauthorized access and ensuring that messages are not tampered with during transmission.
- These technologies are essential in various applications, from online banking to secure email communication, making them vital components in the digital world.
- In this article, we will learn about the RSA signature scheme, **Attacks on the RSA Digital Signature Scheme**, and the steps of digital signature process creation.

Authentication in Asymmetric Key Cryptography

- **RSA Signature Scheme**
- Let us understand how RSA can be used for performing **digital signatures step-by-step**.
- Assume that there is a sender (A) and a receiver (B).
- A wants to send a message (M) to B along with the digital signature (DS) calculated over the message.

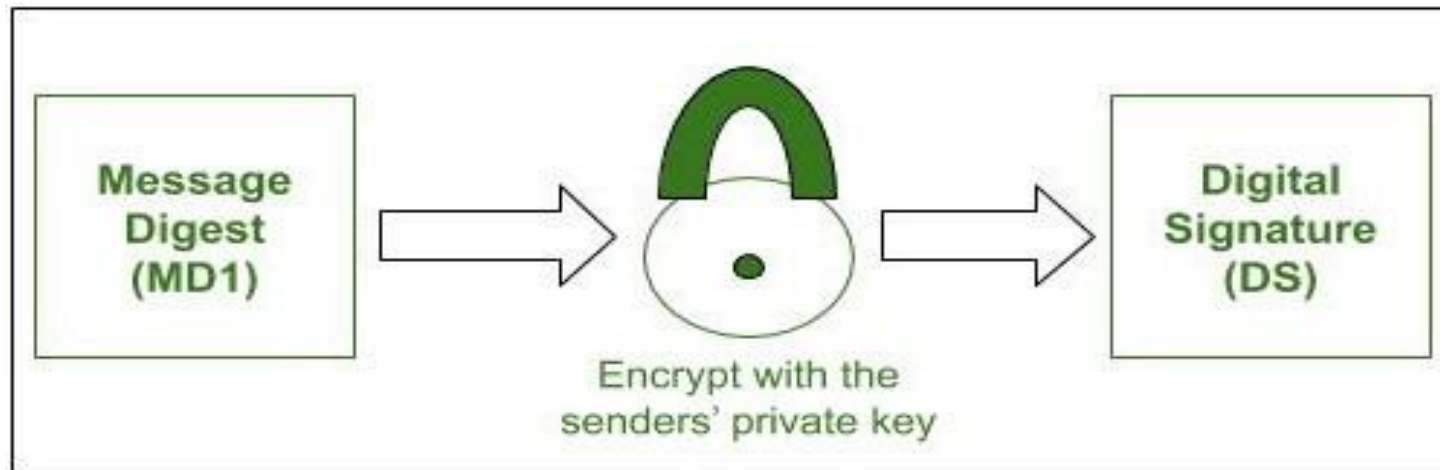
Authentication in Asymmetric Key Cryptography

- **Step 1:** Sender A uses the SHA-1 Message Digest Algorithm to calculate the message digest (MD1) over the original message M.



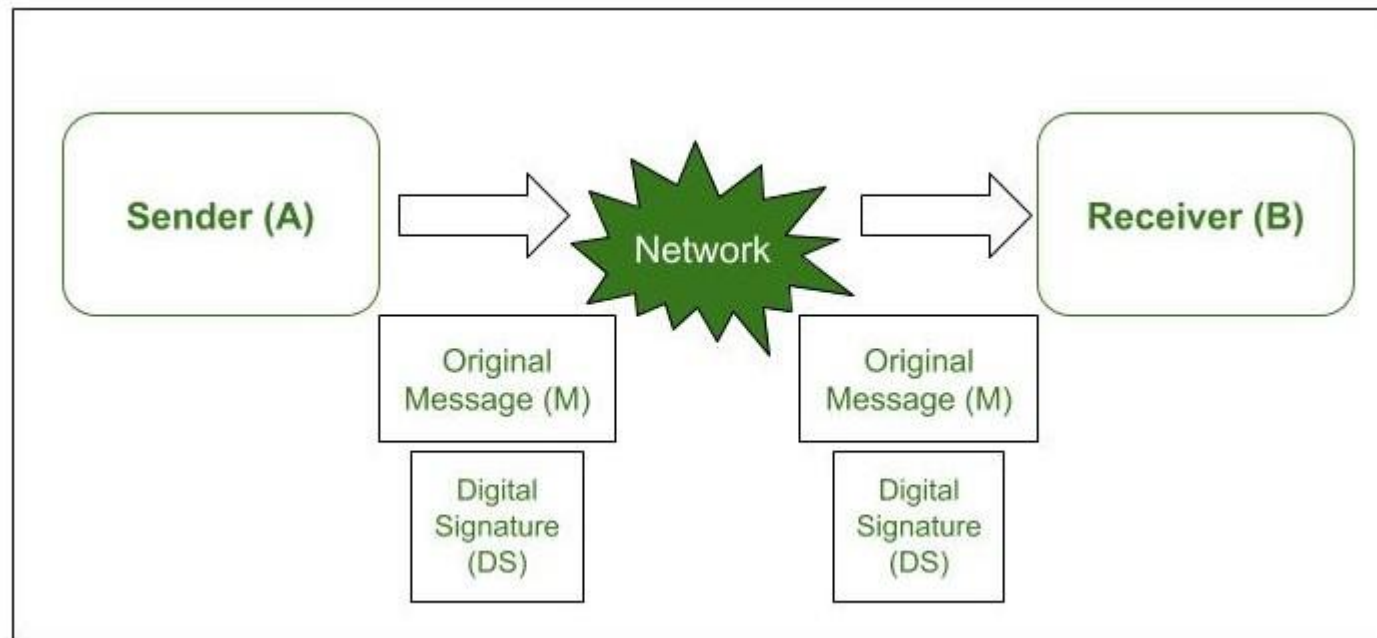
Authentication in Asymmetric Key Cryptography

- **Step 2 :** A now encrypts the message digest with its private key.
- The output of this process is called Digital Signature (DS) of A.



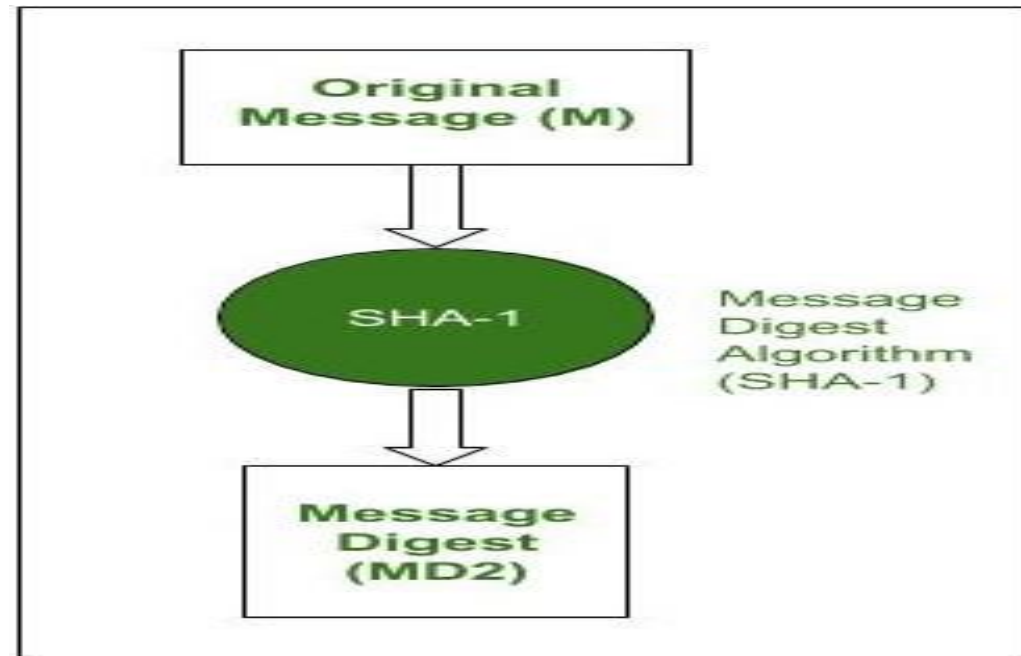
Authentication in Asymmetric Key Cryptography

- **Step 3 :** Now sender A sends the digital signature (DS) along with the original message (M) to B.



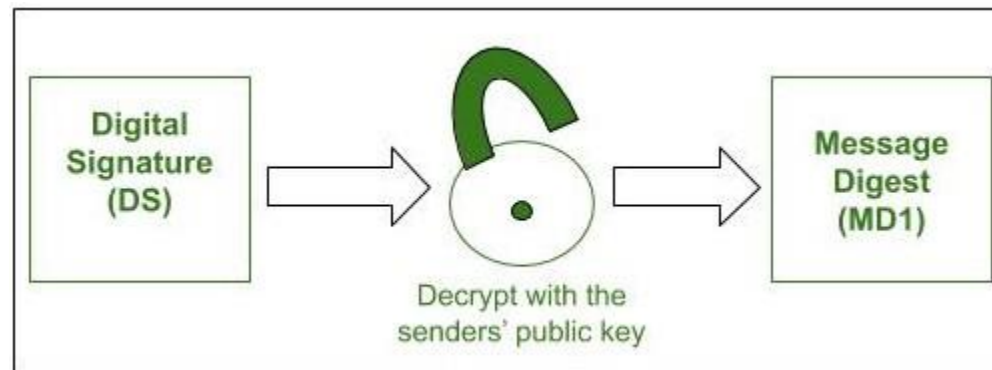
Authentication in Asymmetric Key Cryptography

- **Step 4 :** When B receives the Original Message(M) and the Digital Signature(DS) from A, it first uses the same message-digest algorithm as was used by A and calculates its own Message Digest (MD2) for M.



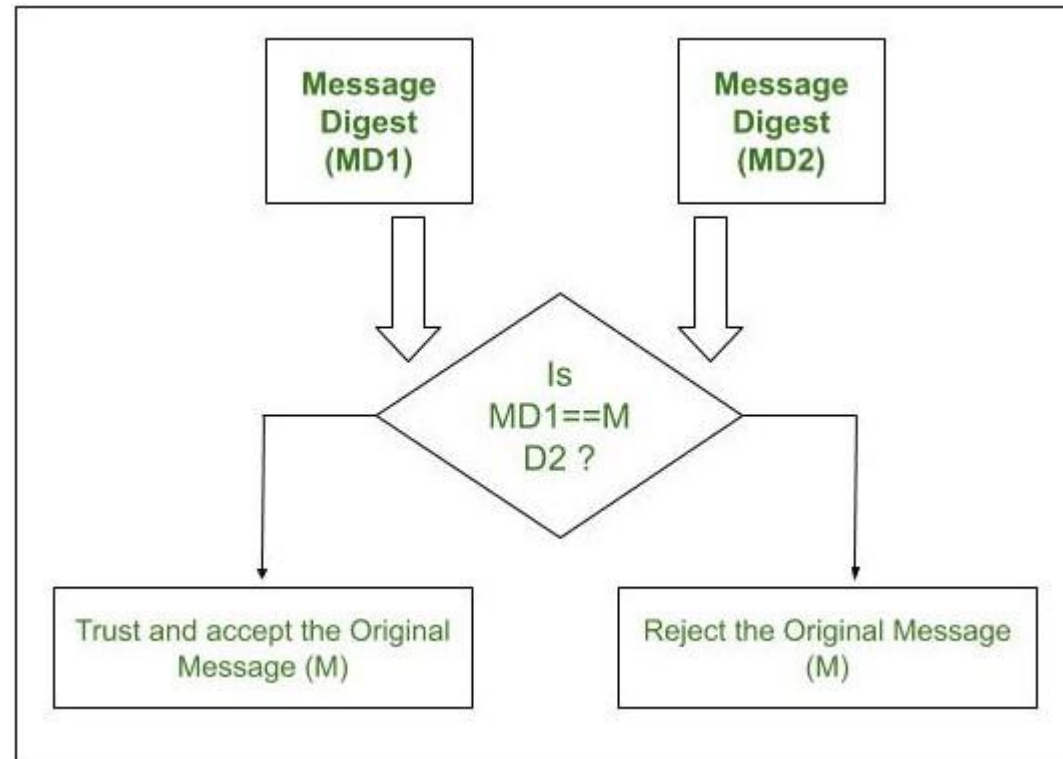
Authentication in Asymmetric Key Cryptography

- **Step 5 :** Now B uses A's public key to decrypt the digital signature because it was encrypted by A's private key.
- The result of this process is the original Message Digest (MD1) which was calculated by A.



Authentication in Asymmetric Key Cryptography

- **Step-6** : If $MD1 == MD2$, the following facts are established as follows.
 - B accepts the original message M as the correct, unaltered message from A.
 - It also ensures that the message came from A and not someone posing as A.



Authentication in Asymmetric Key Cryptography

- The message digest (MD1) was encrypted using A's private key to produce a digital signature.
- Therefore, the digital signature can be decrypted using A's public key (due to asymmetric form of RSA).
- If the receiver B is able to decrypt the digital signature using A's public key, it means that the message is received from A itself and now A cannot deny that he/she has not sent the message.
- It also proves that the original message did not tamper because when the receiver B tried to find its own message digest MD2, it matched with that of A's MD1.
- Suppose a malicious user tries to access the original message and perform some alteration.

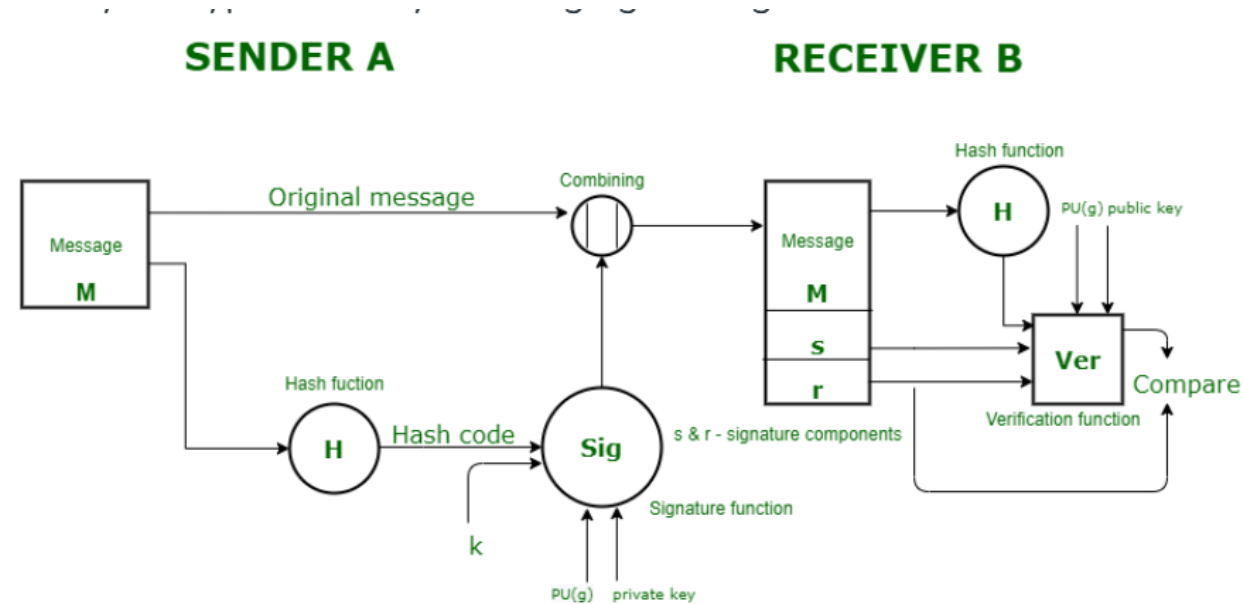
Authentication in Asymmetric Key Cryptography

- Now he/she will calculate a new message digest over the altered message.
- It might concern you with data integrity and confidentiality but here's the catch.
- The attacker will have to sign the altered message using A's private key in order to pose as A for the receiver B.
- However, an attacker cannot sign the message with A's private key because it is known to A only.
- Hence, the RSA signature is quite strong, secure, and reliable.

Authentication in Asymmetric Key Cryptography

- **Digital Signature Standard (DSS)**
- As we have studied, signature is a way of authenticating the data coming from a trusted individual.
- Similarly, digital signature is a way of authenticating a digital data coming from a trusted source.
- **Digital Signature Standard (DSS)** is a Federal Information Processing Standard(FIPS) which defines algorithms that are used to generate digital signatures with the help of Secure Hash Algorithm(SHA) for the authentication of electronic documents.
- DSS only provides us with the digital signature function and not with any encryption or key exchanging strategies.

Authentication in Asymmetric Key Cryptography



Sign any document online efficiently and organize your workflow with the user-friendly and highly secure e-signature platform [SignNow](#). With this, you can easily share any electronic documents for signature, keep track of them, and even sign the documents on any device.

Authentication in Asymmetric Key Cryptography

- **Sender Side:**
- In DSS Approach, a hash code is generated out of the message and following inputs are given to the signature function –
 - 1. The hash code.
 - 2. The random number 'k' generated for that particular signature.
 - 3. The private key of the sender i.e., $PR(a)$.
 - 4. A global public key(which is a set of parameters for the communicating principles) i.e., $PU(g)$.
- These input to the function will provide us with the output signature containing two components - 's' and 'r'.
- Therefore, the original message concatenated with the signature is sent to the receiver.

Authentication in Asymmetric Key Cryptography

- **Receiver Side :** At the receiver end, verification of the sender is done. The hash code of the sent message is generated.
- There is a verification function which takes the following inputs -
 - 1. The hash code generated by the receiver.
 - 2. Signature components 's' and 'r'.
 - 3. Public key of the sender.
 - 4. Global public key.
- The output of the verification function is compared with the signature component 'r'.
- Both the values will match if the sent signature is valid because only the sender with the help of its private key can generate a valid signature.

Key Establishment

- The **n^2 key distribution problem** is a classic issue in **symmetric-key cryptography** and **network security**.
- **What is the n^2 Key Distribution Problem?**
- In a network with **n users**, if **each pair of users must share a unique secret key** (symmetric encryption), then the total number of keys required is:
 - $$n(n-1)/2 \approx O(n^2)$$
- This rapid growth in the number of keys creates serious **scalability and management problems**.

Key Establishment

- **Why is it a Problem?**
- Each user must:
- Store $n-1$ secret keys
- Securely distribute those keys beforehand
- As n increases, key storage and secure distribution become impractical.

Key Establishment

Number of users (n)	Keys required
2	1
5	10
10	45
100	4,950
1,000	499,500

So in a large organization, managing keys becomes unmanageable.

Key Establishment

- **Issues Caused**
- Complex key management
- High storage requirements
- Difficult key revocation
- Increased risk if a user is compromised
- Not scalable for large networks

Key Establishment

- **How Is the Problem Solved?**
- **Public-Key Cryptography**
- Each user keeps:
- One **public key**
- One **private key**
- No need for n^2 shared keys.
- Examples: RSA, Diffie–Hellman, ECC.
- **Key Distribution Center (KDC)**
- Each user shares **one master key** with a trusted center.
- Total keys: n
- Used in Kerberos system

Key Establishment

- **Hybrid Cryptosystems**
- Use public-key crypto to exchange a session key
- Use symmetric crypto for data encryption
- (Used in HTTPS, TLS)

Key Establishment

- **Key Distribution Center (KDC)**
- A Key Distribution Center (KDC) is a crucial component within the architecture of network security, particularly in the implementation of Kerberos protocol.
- The KDC is responsible for managing the distribution of secret keys necessary for secure communication between clients and servers within a network.
- The Key Distribution Center (KDC) is fundamental in ensuring secure authentication in networked environments.
- By managing the issuance and distribution of cryptographic keys, the KDC helps in safeguarding communications and preventing unauthorized access.
- The KDC operates within a larger authentication framework, playing a pivotal role in protocols such as Kerberos, which are designed to enable secure identity verification over potentially insecure networks.

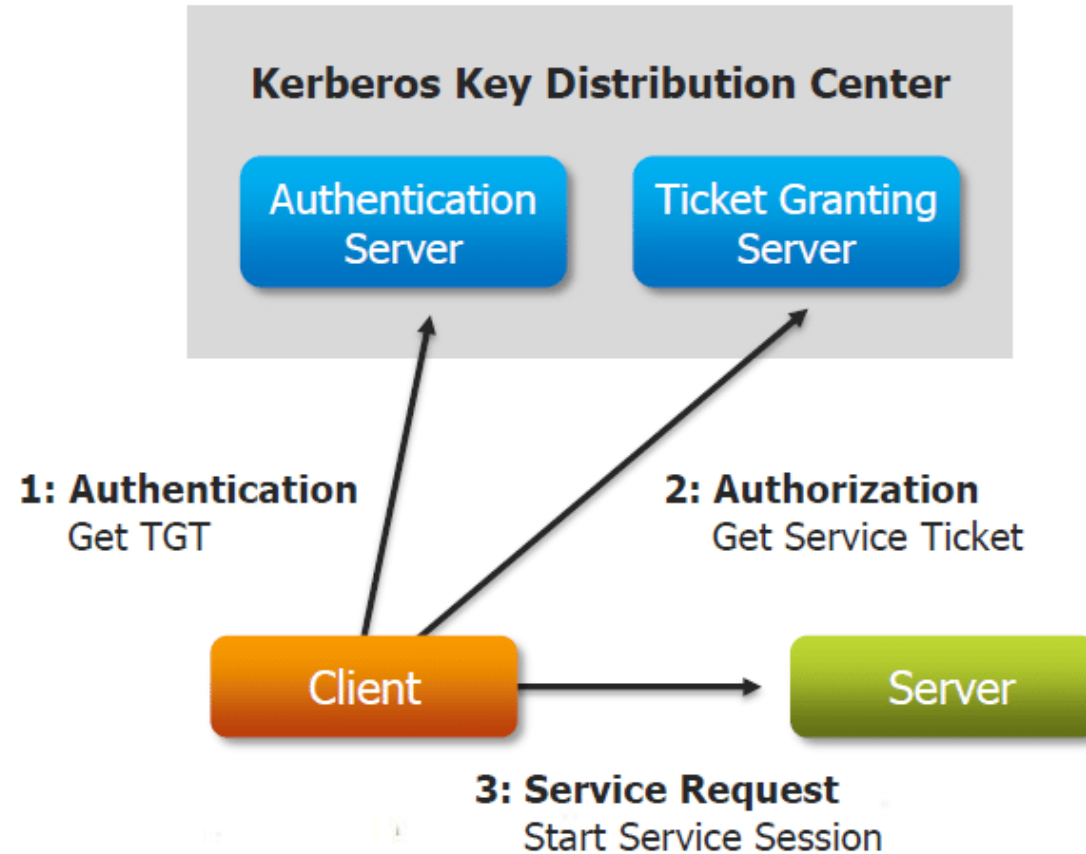
Key Establishment

- **Components of KDC**
- A KDC typically consists of two main components:
- **Authentication Server (AS):** This component is responsible for authenticating users when they first log in.
- It issues Ticket Granting Tickets (TGTs) to authenticated users.
- **Ticket Granting Server (TGS):** This component provides service tickets based on the TGTs issued by the AS, allowing users to access various services securely without re-authenticating.

Key Establishment

- **How KDC Works**
- The KDC's workflow can be broken down into several steps:
- **Initial Authentication:**
 - A user sends a request to the Authentication Server (AS) with their credentials.
 - The AS verifies the credentials. If valid, it issues a Ticket Granting Ticket (TGT) encrypted with the user's secret key.
- **Service Request:**
 - The user presents the TGT to the Ticket Granting Server (TGS) when requesting access to a specific service.
 - The TGS validates the TGT, and if valid, issues a service ticket encrypted with the service's secret key.
- **Service Access:**
 - The user presents the service ticket to the desired service.
 - The service decrypts the ticket and allows access if the ticket is valid.

Key Establishment



Key Establishment

- **Benefits of Using a KDC**
- Implementing a Key Distribution Center in a network brings several advantages:
- **Enhanced Security:** By centralizing key management, the KDC minimizes the risk of key compromise. Keys are not stored on individual client devices, reducing the attack surface.
- **Simplified Key Management:** The KDC automates the distribution and management of cryptographic keys, simplifying administrative overhead.
- **Scalability:** KDCs can support large numbers of users and services, making them suitable for enterprise-level environments.
- **Single Sign-On (SSO):** Users authenticate once to the KDC and can then access multiple services without needing to re-enter credentials.

Key Establishment

- **Uses of KDC**
- Key Distribution Centers are widely used in environments that require robust security and efficient key management. Common use cases include:
- **Enterprise Networks:** KDCs are integral to corporate networks using Kerberos for secure authentication.
- **Educational Institutions:** Universities and schools use KDCs to manage student and faculty access to various resources.
- **Healthcare Systems:** Secure access to patient records and other sensitive information is managed through KDCs.
- **Government Agencies:** KDCs help in safeguarding sensitive data and ensuring secure communication within and between departments.

Key Establishment

- **Setting Up a KDC**
- Implementing a Key Distribution Center involves several steps:
- **Choosing a Kerberos Implementation:** Various implementations are available, such as MIT Kerberos and Microsoft Active Directory.
- **Installing the KDC Software:** Install the KDC software on a secure server. Ensure the server is hardened against attacks.
- **Configuring the KDC:** Define the realm (network domain), set up principals (users and services), and configure encryption policies.
- **Testing the Setup:** Before deploying, thoroughly test the KDC in a controlled environment to ensure it functions correctly.
- **Deploying to Production:** Once testing is complete, deploy the KDC to the production environment. Monitor its operation and perform regular maintenance.

Key Establishment

- **Challenges in Using KDC**
- While KDCs provide numerous benefits, they also come with certain challenges:
- **Single Point of Failure:** The KDC is a critical component, and its failure can disrupt authentication services across the network.
- **Scalability Issues:** In very large networks, the KDC can become a bottleneck if not properly scaled.
- **Complexity:** Setting up and managing a KDC requires specialized knowledge and careful planning.

Key Establishment

- **Man in the Middle Attack**
- A man-in-the-middle (MitM) attack is a form of cyberattack where important data is intercepted by an attacker using a technique to interject themselves into the communication process.
- The attacker can be a passive listener in your conversation, silently stealing your secrets, or an active participant, altering the contents of your messages, or impersonating the person/system you think you're talking to.
- Think back to the 20th century, when your younger sibling would pick up the phone when you were talking to your crush.
- You didn't know they were listening, and then they went and tattled on you.
- That's a basic MitM attack.

Key Establishment

How Does A Man-in-the-Middle Attack Work?

MitM Attack Process Basics

- 1 Attacker eavesdrops on your conversation



- 2 Peer #1 sends a message to Peer #2



- 3 Attacker intercepts the message between Peers



- 4 Attacker alters the message, steals info, etc.



Key Establishment

- Most MitM attacks follow a straightforward order of operations, regardless of the specific techniques used in the attack.
- In this example, there are three entities, Alice, Bob, and Chuck (the attacker).
- Chuck covertly listens to a channel where Alice and Bob are communicating
- Alice sends a message to Bob.
- Chuck intercepts and reads Alice's message without Alice or Bob knowing.
- Chuck alters messages between Alice and Bob, causing unwanted/damaging responses.

Key Establishment

- Here is a practical example of a real-world MiTM attack against Microsoft Office 365 where MFA(Main factor authentication) was bypassed by the attacker:
- User clicks a phishing link that takes them to a fake Microsoft login page where they enter their username and password.
- The fake webpage forwards the username and password to the attacker's server.
- The attacker forwards the login request to Microsoft, so they don't raise suspicion.
- Microsoft sends the two-factor authentication code to the user via SMS.
- User enters the code into the fake webpage.
- The fake page forwards 2FA(2 factor authentication) code to the attacker's server.
- The attacker uses Evilginx to steal the session cookie.
- The attacker forwards the user's 2FA code to Microsoft, and now the attacker can log in to Office 365 as the compromised user by using the session cookie, and has access to sensitive data inside the enterprise.

Key Establishment

MitM Attack Techniques and Types



Spoofing



Hijacking



Eavesdropping



Intercepting

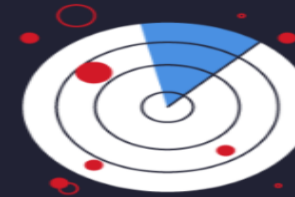
Key Establishment

How to Detect a Man-in-the-Middle Attack

MitM Detection Tips

Keep an eye out for:

- Unexpected and/or repeated disconnections
- Strange addresses in your browser address bar
- Connection to public and/or unsecured wi-fi
- Network connections to unfamiliar locations



Steps to take now:

- Inspect current wi-fi connections
- Check for malware
- Use a network sniffer defensively
- Monitor network activity

Key Establishment

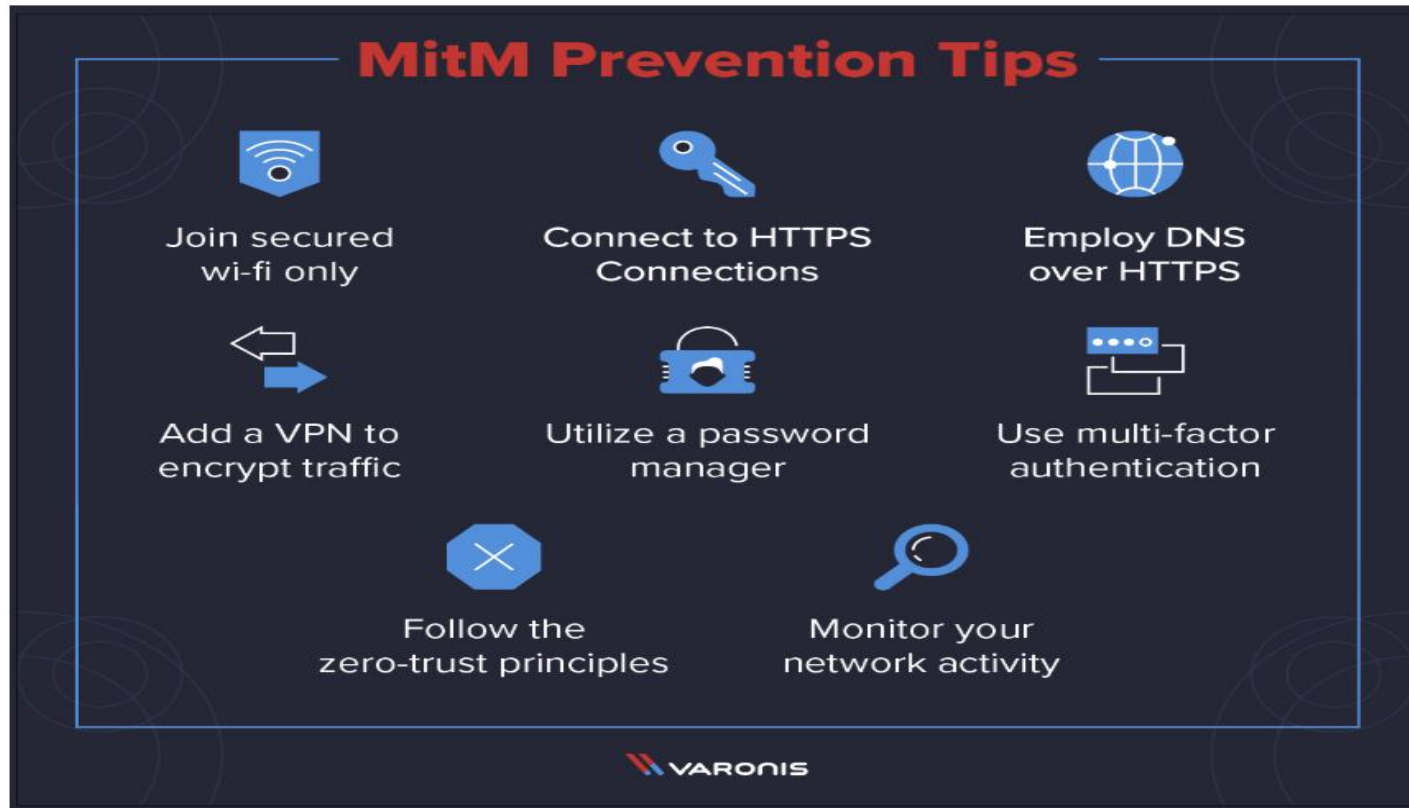
- **Spoofing**
- **Pretending to be a trusted entity** (user or system) to deceive a victim and gain access to communication.
- **RP spoofing:**
An attacker pretends to be the local router on a LAN, tricking devices into sending traffic through the attacker's machine.
- *Result:* Victims believe they are communicating with a trusted device.
- **Hijacking**
- **Taking control of an active session** between two parties without their knowledge.
- **Session hijacking:**
An attacker steals a user's session cookie from an unsecured website and uses it to log in as that user without a password.
- *Result:* Attacker takes over an active session.

Key Establishment

- **Eavesdropping**
- **Secretly listening to or monitoring communication** to steal sensitive information.
- **Public Wi-Fi sniffing:**
An attacker captures unencrypted data (usernames, passwords) from users connected to an open Wi-Fi network.
- *Result:* Information is stolen without modifying traffic.
- **Intercepting**
- **Capturing and possibly altering messages** while they are being transmitted between two parties.
- **HTTPS downgrade attack (SSL stripping):**
- An attacker intercepts HTTPS traffic and forces communication to use HTTP, allowing data modification or theft.
- *Result:* Messages are captured and possibly altered.

Key Establishment

How to Prevent a Man-in-the-Middle Attack



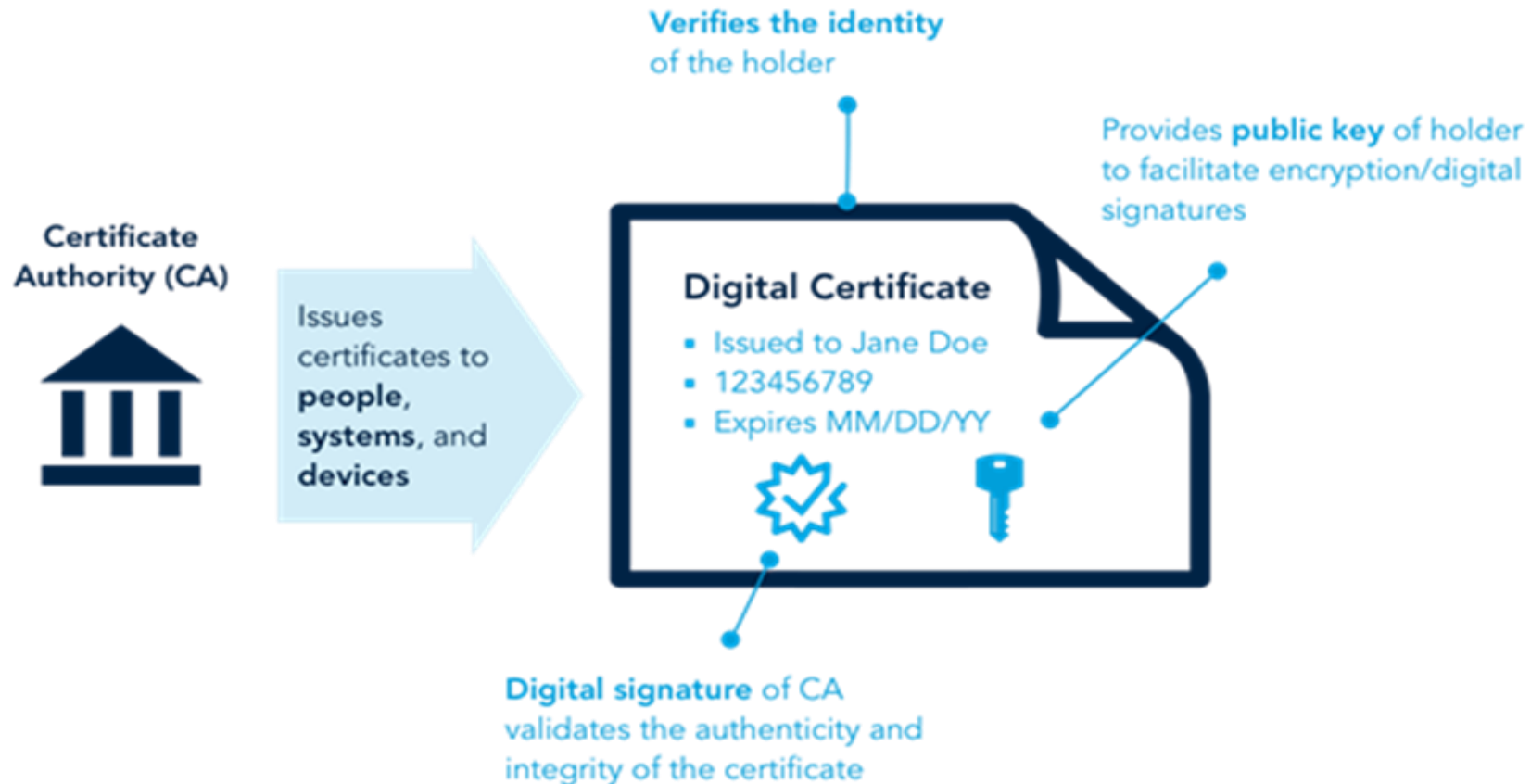
Key Establishment

- **Digital Certificate**
- A digital certificate is a form of electronic credential that can prove the authenticity of a user, device, server, or website.
- It uses PKI to help exchange communications and data securely over the internet.
- This form of authentication is a type of cryptography that requires the use of public and private keys to validate users.
- Public key certificates are issued by trusted third parties, a CA, who signs the certificate, thus verifying the identity of the device or user that is requesting access.
- To ensure validity, the public key will be matched with a corresponding private key that only the recipient has knowledge of.
- Digital certificates have a specific key pair opens in a new tab that they are associated with: one public and one private.

Key Establishment

- A digital certificate contains the following identifiable information:
- User's name
- Company or department of user
- IP (internet protocol) address or serial number of device
- Copy of the public key from a certificate holder
- Duration of time the certificate is valid for
- Domain certificate is authorized to represent

Key Establishment



Key Establishment

- **Different types of digital certification**
- **TLS/SSL certificates**
- The TLS/SSL certificate is used to secure communications between a computer and the server, and it is hosted by the server.
- When a client computer seeks to access the server, the server will present the digital certificate to prove that it is authentic and the desired destination.
- The HTTPS (Hypertext Transfer Protocol Secure) designation at the beginning of a web address or URL (Uniform Resource Locator) indicates the presence of a digital certificate.

Key Establishment

- **Client certificates**
- This is a form of a digital ID that can identify one machine to another —a specific user to another user.
- This can be used to allow a user to access a protected and secure database and also for email.
- With email, often the S/MIME opens in a new tab(Secure/Multipurpose Internet Mail Extensions) protocol is used, which works for communications within an organization.
- Both parties will need to have copies of the digital certificate before communicating.

Key Establishment

- **Code signing certificates**
- This type of digital certificate involves software or files.
- The publisher or developer of software will sign it to validate its authenticity to users downloading it.
- This can be highly beneficial when software is downloaded through a third-party, ensuring that it is what it should be and has not been tampered with by malicious actors.
- This can confirm that files or software downloaded from the internet are valid and authentic.

Key Establishment

- **Benefits of digital certification**
- Digital certification can offer a level of security that is increasingly important in this digital age.
- In fact, cybersecurity has been named one of the top priorities of the U.S. Government by the Department of Homeland Security (DHS).
- Cybercrime is a major threat to businesses and individuals.
- Digital certificates can provide the following benefits:
- **Security:** Digital certificates can keep internal and external communications confidential and protect the integrity of the data.
- It can also provide access control, ensuring only the intended recipient receives and can access the data.

Key Establishment

- **Authentication:** With a digital certificate, users can be sure that the entity or person they are communicating with is who they say they are and makes sure that communications reach only the intended recipient.
- **Scalability:** Digital certificates can be used across a variety of platforms for individuals and large and small businesses alike.
- They can be issued, renewed, and revoked in a matter of seconds.
- They can be used to secure a range of user devices and be managed through one centralized system.

Key Establishment

- **Reliability:** A digital certificate can only be issued by a publicly trusted and rigorously vetted CA, meaning that they cannot be easily tricked or faked.
- **Public trust:** The use of a digital certificate proves authenticity of a website, documents, or emails.
- It can assure users and clients that the company or individual is genuine and respects privacy and values security.

THANK YOU